

MAPEO NORMATIVO DETALLADO

Encuesta FAICP 2025-2026: Cada Pregunta y sus Anclajes Regulatorios

"Una pregunta sin ancla normativa es una opinión. Una norma sin pregunta que la evalúe es un deseo. El mapeo que sigue intenta ser ambas cosas a la vez: sistemático y útil."

Versión: 1.0 — Abril 2026 | **Formato:** Tablas de concordancias exhaustivas

LEYENDA DE MARCOS NORMATIVOS

Sigla	Marco / Norma	Versión/Año	Tipo
NIST-CAP	NIST IR 8596 Cyber AI Profile	Dic. 2025 (borrador)	Técnico (EE.UU.)
NIST-RMF	NIST AI RMF 1.0 (AI 100-1)	Ene. 2023 / 2025	Técnico (EE.UU.)
EU-AIA	EU AI Act (Reglamento UE 2024/1689)	Feb. 2025 (aplic.)	Legal (UE)
NIS2	Directiva NIS2 (UE 2022/2555)	Oct. 2024	Legal (UE)
ENS	ENS RD 311/2022 (España)	May. 2022	Legal (ES)
ISO-42001	ISO/IEC 42001:2023	2023	Norma (ISO)
ISO-27001	ISO/IEC 27001:2022	2022	Norma (ISO)
OWASP-LLM	OWASP Top 10 LLM Applications 2025	Nov. 2024	Técnico
ATLAS	MITRE ATLAS	Oct. 2025	Técnico
DORA	Digital Operational Resilience Act (UE 2022/2554)	Ene. 2025	Legal (UE)
RGPD	Reglamento General Protección de Datos	May. 2018	Legal (UE)

SECCIÓN 1 — FUNCIÓN GOBERNAR

Pregunta	NIST-CAP	NIST-RMF	EU-AIA	NIS2	ENS	ISO-42001
P1.1 Política IA	GV.OC-04	GOVERN 1.2	Art. 9 (Gestión riesgos)	Art. 21.2.a	Art. 12	Cl. 6.1 + 5.2
P1.2 Dependencias infraestructura	GV.OC-05	MAP 2.1	Art. 9.2.b	Art. 21.3	Art. 14.2	Cl. 8.4
P1.3 RRHH + amenazas IA	GV.RR-04	GOVERN 4.1	Art. 4 (Alfabetización IA)	Art. 21.2.g	Art. 16	Cl. 7.2 + 7.3
P1.4 Cadena suministro IA	GV.SC-07	GOVERN 6.2	Art. 9.2.b + Art. 25	Art. 21.3	Art. 14.3	Cl. 8.4
P1.5 Comité IA	GV.RR-02	GOVERN 1.1 + 1.7	Art. 26.4	Art. 20.1	Art. 12.1	Cl. 5.1
P1.6 Registro EU AI Act	GV.OC-04	MAP 1.1	Art. 49 (Registro obligatorio)	—	—	Cl. 9.1

SECCIÓN 2 — FUNCIÓN IDENTIFICAR

Pregunta	NIST-CAP	NIST-RMF	EU-AIA	NIS2	ISO-42001	OWASP-LLM	ATLAS
P2.1 AI-BOM / Inventario IA	ID.AM-07	MAP 3.5	Art. 11 (Documentación técnica)	Art. 21.2.b	Cl. 8.1 + 8.3	LLM03	AML.T0047
P2.2 Vulnerabilidades IA	ID.RA-01	MEASURE 2.5	Art. 9.2.c	Art. 21.2.b	Cl. 8.4.1	LLM01-LLM09	Múltiples
P2.3 Amenazas adversariales	ID.RA-03	MAP 5.1	Art. 9.2.a	Art. 21.2.b	Cl. 8.4	—	AML.T0001-T0015
P2.4 Velocidad ataques IA	ID.RA-04	MEASURE 2.6	Art. 9.3	Art. 21.2.b	Cl. 8.4.2	—	AML.T0043
P2.5 Riesgos cadena suministro	ID.SC-02	MAP 5.2	Art. 9.2.b + Art. 25	Art. 21.3	Cl. 8.4	LLM03	AML.T0047

SECCIÓN 3 — FUNCIÓN PROTEGER

Pregunta	NIST-CAP	EU-AIA	NIS2	ENS	ISO-42001	OWASP-LLM
P3.1 IAM para sistemas IA	PR.AA-01	Art. 15.1	Art. 21.2.e	Art. 17	Cl. 8.7	LLM06
P3.2 Menor privilegio agentes IA	PR.AA-05	Art. 15.1	Art. 21.2.e	Art. 17	Cl. 8.7	LLM06
P3.3 Formación amenazas IA	PR.AT-01	Art. 4 (Alfabetización IA)	Art. 21.2.g	Art. 16	Cl. 7.2-7.3	—
P3.4 Protección datos entrenamiento	PR.DS-01/10	Art. 10 (Datos entrenamiento)	Art. 21.2.c	Art. 19	Cl. 8.5	LLM02 + LLM04
P3.5 Control versiones MLOps	PR.PS-01	Art. 9.1.g	Art. 21.2.b	Art. 23	Cl. 8.3	—
P3.6 Agencia excesiva	ID.RA-02	Art. 14 (Supervisión humana)	—	—	Cl. 8.6	LLM06

SECCIÓN 4 — FUNCIÓN DETECTAR

Pregunta	NIST-CAP	EU-AIA	NIS2	ENS	ISO-42001	OWASP-LLM	ATLAS
P4.1 Monitorización APIs IA	DE.CM-06	Art. 72 (Vigilancia poscom.)	Art. 21.2.b	Art. 24	Cl. 9.1	LLM10 + LLM02	—
P4.2 Monitorización runtime IA	DE.CM-09	Art. 72 + Art. 9.1.g	Art. 21.2.b	Art. 24	Cl. 9.1	LLM06 + LLM10	AML.T0049
P4.3 Model drift	DE.AE-02	Art. 72.1 (Monitorización rendimiento)	—	—	Cl. 9.1	—	AML.T0054
P4.4 SOC con capacidades IA	DE.CM-01	—	Art. 21.2.b	Art. 24	—	—	ATLAS múltiples
P4.5 Detección prompt injection	DE.CM-03	Art. 15.1	Art. 21.2.b	Art. 24	Cl. 8.7	LLM01	AML.T0051

SECCIÓN 5 — FUNCIÓN RESPONDER

Pregunta	NIST-CAP	NIST-RMF	EU-AIA	NIS2	ENS	ISO-27001
P5.1 Playbooks IA	RS.MA-01/ RS.AN-03	MANAGE 4.2	Art. 9.2.d	Art. 21.2.b	Art. 25	A.5.26
P5.2 Forense IA	RS.AN-03	MANAGE 4.3	Art. 72.2 (Trazabilidad)	Art. 21.2.b	Art. 25	A.5.28
P5.3 Notificación AESIA/CCN	RS.CO-02	MANAGE 4.2	Art. 73 (≤15 días hábiles)	Art. 23 (24h/72h)	Art. 25.3	A.5.24
P5.4 MTTR-AI	RS.AN-03	MEASURE 4.2	Art. 9 (Gestión riesgos)	Art. 21.2.b	Art. 25	—

SECCIÓN 6 — FUNCIÓN RECUPERAR

Pregunta	NIST-CAP	NIST-RMF	EU-AIA	NIS2	ENS	DORA
P6.1 Planes de recuperación IA	RC.RP-02	MANAGE 4.4	Art. 9.2.d	Art. 21.2.c	Art. 26	Art. 11 (TLPT)
P6.2 RTO-AI	RC.RP-02	MANAGE 4.4	—	Art. 21.2.c	Art. 26	Art. 24 (RTO sector financiero)
P6.3 Revisión de decisiones comprometidas	RC.RP-03	MANAGE 4.4	Art. 72.1 (Vigilancia output)	—	Art. 26	—

SECCIÓN 7 — OT/ICS + IA

Pregunta	NIST-CAP	EU-AIA	NIS2	ENS	ISA/IEC 62443
P7.1 IA en sistemas ICS	GV.OC-05	Anexo III.9 (Infraestructuras críticas)	Anexo I (Sectores críticos)	Art. 3	SR 1.1
P7.2 Evaluación de riesgo OT-IA	ID.RA-04	Art. 9.2	Art. 21.2.b	Art. 14	SR 3.2
P7.3 Segregación IT/OT	PR.IR-04	—	Art. 21.2.h	Art. 18	SR 5.1
P7.4 Ejercicios de red team OT+IA	RS.MA-04	—	Art. 21.2.i	Art. 26	SR 6.2

SECCIÓN 8 — CUMPLIMIENTO NORMATIVO

Pregunta	Marco Principal	Artículos Clave	Sanciones por Incumplimiento
P8.1 EU AI Act	EU-AIA	Arts. 6-51 (Sistemas alto riesgo)	Hasta 30M€ o 6% volumen global
P8.2 ENS	ENS RD 311/2022	Arts. 37-40 (Auditoría/certificación)	Responsabilidad disciplinaria AAPP
P8.3 NIS2	NIS2 + RD transposición ES	Art. 21 (Medidas gestión riesgos)	Hasta 10M€ o 2% facturación global
P8.4 ISO/IEC 42001	ISO-42001	Cláusulas 1-10	Voluntario (no sanción directa)
P8.5 FRIA/DPIA IA	EU-AIA + RGPD	Art. 27 AIA + Art. 35 RGPD	Hasta 30M€ (AIA) + 20M€ (RGPD)

SECCIÓN 9 — AESIA

Pregunta	Marco	Documentos AESIA	Artículos EU AI Act
P9.1 Guías AESIA	EU-AIA + AESIA	16 Guías Prácticas (dic. 2025)	Arts. 9-15 (Capítulo III)
P9.2 Sandbox regulatorio	EU-AIA Art. 57-63	RD 817/2023 (sandbox español)	Arts. 57-63
P9.3 Registro incidentes IA	EU-AIA Art. 73 + NIST-CAP	Guía 11 AESIA	Art. 73 (15 días hábiles)

RESUMEN DE COBERTURA NORMATIVA

Marco	Preguntas que lo referencian	Secciones principales
NIST IR 8596 (Cyber AI Profile)	38	1-6 (todas)
EU AI Act	29	1, 2, 3, 5, 6, 8, 9
NIST AI RMF 1.0	24	1-6 (todas)
NIS2	22	1-8
ISO/IEC 42001	20	1-6
OWASP LLM Top 10	15	2, 3, 4
ENS RD 311/2022	18	1-7
ISO/IEC 27001	14	1-6
MITRE ATLAS	10	2, 4
DORA	4	6, 8
RGPD	6	3, 8
ISA/IEC 62443	4	7

Kit FAICP 2025–2026 · Documento (d) · Versión 1.0 · Abril 2026

Las referencias son orientativas; consultar texto legal completo para aplicación jurídica.